

实验分析报告

邮件垃圾信息 AI 识别 方案试点效果分析

编制方：待确认

2026 年 7 月 17 日

文档控制

版本	v0.1
编制方	待确认（建议：信息安全与邮件运营联合小组）
评审方	待确认（邮件管理员、信息安全、隐私/合规、业务代表）
编制日期	2026-07-17
报告周期	待试点启动后填写
状态	试点前分析方案（草案）

文档目的

本文档用于定义并记录公司在 Microsoft 365 邮件环境中开展的“公共邮箱来信 AI 辅助识别”试点，包括目标、范围、执行方法、评价指标、结果填写要求以及后续决策门槛。试点对象是来自 126、新浪、QQ、Gmail、Outlook 等公共邮件服务商、投递给公司内部收件人的外部邮件。

本文档供邮件管理员、信息安全、隐私与合规、业务代表及项目负责人共同使用。它将统一样本口径、人工标注规则和放行标准，为审计、复现、模型迭代及是否进入自动隔离阶段提供可追溯依据。

业务背景

公司当前使用 Office 365。已观察到来自 126、新浪等公共邮箱服务的发件人向多名内部员工发送垃圾邮件。现有反垃圾邮件策略能够处理部分威胁，但仍有漏检，且攻击者可能频繁更换具体账号，因此仅维护静态阻止名单难以覆盖全部变体。当前证据为已报告事件和管理员观察；基线邮件量、漏检率及误报率尚未提供，需在试点中建立。

公共邮箱域本身并不代表恶意，直接封禁整个域会误伤候选人、客户和供应商。试点选择在现有 EOP/Defender 之后增加受控的 AI 二次判别，以利用邮件头、认证结果、收件人范围、正文、链接和历史相似度等信号。首阶段采用旁路评估，不改变原始投递，可随时停用；原有反病毒、反钓鱼和附件检测保持不变。

试点概览

字段	内容
试点名称	邮件垃圾信息 AI 识别方案试点
试点编号	MAIL-AI-PILOT-001
牵头团队	待确认（建议：信息安全与邮件运营）
业务负责人	待确认
系统范围	Exchange Online 进站邮件流、EOP/Defender、受控 AI 分析队列
主要目标	验证 AI 二次判别能否提升公共邮箱垃圾邮件识别效果，并控制误报、时延和隐私风险
对照方案（A）	现有 EOP/Defender、反垃圾策略、邮件流规则及阻止名单，不使用 AI 判定
处理方案（B）	在旁路队列中对相同邮件增加 AI 风险评分、原因和建议动作，首阶段不改变投递
分配方式	配对评估：每封符合条件的唯一邮件均由 A、B 两种方法评分
分析单元	唯一邮件（Network Message ID），跨多个内部收件人去重
覆盖对象	来自公共邮箱域清单、发往试点用户组的外部邮件
排除项	内部邮件、可信白名单、系统通知、无法合规处理的加密内容及测试邮件
开始日期	待确认
结束日期	待确认
计划周期	建议 4 周：2 周基线收集 + 2 周稳定性验证
实际周期	待试点完成后填写

试点设计说明

采用配对旁路评估：每封符合范围的唯一邮件同时保留现有系统判定和 AI 判定，再由双人复核形成参考标签。唯一变化是增加 AI 风险评分与建议动作；现有 EOP/Defender、邮件流规则、租户阻止名单和用户投递流程均保持不变。由于同一邮件由两种方法共同评分，结果可直接比较召回率、误报率和处理时延。

以 Network Message ID 去重，将同一封群发邮件视为一个分析单元，同时保留内部收件人数作为特征。纳入来自维护清单中公共邮箱域、发往试点用户组的外部邮件；排除内部邮件、可信合作方白名单、系统通知、无法依法处理的加密内容以及超过连接器处理限制的邮件。建议运行 4 周，先收集 2 周基线，再完成 2 周稳定性验证。

试点假设

如果在现有 EOP/Defender 判定基础上，对试点用户收到的公共邮箱来信增加 AI 二次评分，并结合发件认证、群发范围、正文、链接及历史相似度，那么相较仅使用现有规则，已确认垃圾邮件的召回率和综合 F1 应提高，同时正常邮件误报率维持在可接受范围内，因为 AI 能够识别跨账号重复、语义诱导和多信号组合模式。

成功标准

主要成功指标为已确认垃圾邮件召回率相对现有方案提升。以下阈值均为试点建议值，须由业务和安全负责人批准后冻结。只有主要指标达到门槛，且误报率、处理时延、未处理率和隐私合规护栏全部通过，才可进入小范围自动隔离；否则继续旁路优化或终止试点。

指标	建议目标/规则（试点前需批准）
主要指标	垃圾邮件召回率较现有方案提升不少于 10 个百分点，且 95%置信区间下限大于 0
护栏 1	正常邮件误报率不高于 0.5%，且不得自动阻断业务关键正常邮件
护栏 2	AI 端到端处理时延 P95 不高于 60 秒
护栏 3	未处理率不高于 0.1%，故障时默认回退现有邮件策略
决策规则	主要指标达标且全部护栏通过，方可进入小范围人工审批；自动隔离需另行批准

上线前验证

- 确认对照与处理结果仅相差 AI 二次评分及建议动作，原有安全策略与样本范围一致。
- 确认以唯一邮件为分析单元，并按 Network Message ID 去重；同一邮件的所有收件人记录保持一致。
- 验证邮件采集、EOP/Defender 判定、AI 结果、人工标签、处理时延及异常状态均可关联和审计。
- 冻结公共邮箱域清单、可信地址例外、系统邮件例外、加密邮件处理方式及测试数据排除规则。
- 完成离线样本回放、提示词注入测试、权限最小化检查、敏感数据留存检查及故障降级演练；结果待上线前填写。

样本与覆盖概览

当前尚未启动试点，因此没有可用于效果结论的样本量、运行时长或标签分布。试点结束后应报告唯一邮件数、公共邮箱域分布、垃圾与正常样本数、无法解析比例及标注一致率；在最低有效样本和数据质量门槛达成前，不得宣布方案有效。

样本指标	对照方案 (A)	AI 方案 (B)
符合条件的唯一邮件数	待试点	与 A 相同的配对样本
人工确认垃圾邮件数	待试点	与 A 相同的参考标签
人工确认正常邮件数	待试点	与 A 相同的参考标签
有效判定覆盖率	待试点	待试点
样本一致性检查	待试点	待试点

主要结果

度量	对照方案 A	AI 方案 B	绝对差异	相对差异
垃圾邮件召回率	待试点	待试点	待计算	待计算
95%置信区间	待计算	待计算	待计算	不适用
配对检验 p 值	不适用	不适用	待计算	不适用
结果说明	待试点	待试点	需结合误报与实际案例解释	不适用

结果待试点完成后填写。目前只能确认分析方法和决策门槛，不能据此声称 AI 已提高垃圾邮件识别效果。最终应同时报告点估计、95%置信区间、配对检验结果和实际误拦截案例。

护栏指标

护栏指标	对照方案 A	AI 方案 B	差异	状态
正常邮件误报率	待试点	待试点	待计算	待判定
处理时延 P95	不适用	待试点	不适用	待判定
未处理率	待试点	待试点	待计算	待判定
隐私/安全事件数	待试点	待试点	待计算	待判定

所有护栏结果均待试点数据。任一护栏未通过时，不进入自动拦截；特别是出现业务关键正常邮件被自动阻断、未授权数据外传或模型服务无法安全降级时，应立即停止处理方案并回退到现有邮件策略。

分群结果

预先分析公共邮箱服务商、收件人数、邮件是否含链接或附件、内部收件部门和中文/非中文内容等分群。这些分群用于识别误报集中区域和攻击模式差异。除非每个分群达到预先约定的最小样本量，否则分群结果仅作方向性参考，不作确认性结论。

预设分群	对照方案值	AI 方案值	绝对差异	解释
公共邮箱服务商	待试点	待试点	待计算	比较 126/新浪/ QQ 等，但避免域名污名化
内部收件人数	待试点	待试点	待计算	关注单人来信与多人群发差异
含链接/不含链接	待试点	待试点	待计算	验证 URL 与跳转信号增量
含附件/不含附件	待试点	待试点	待计算	AI 不替代附件恶意检测
中文/非中文内容	待试点	待试点	待计算	检查语言差异与模型偏差

分群结果待试点完成后填写。分析时需报告各分群样本量，并控制多重比较带来的偶然差异；不得只展示表现最好的服务商或部门。

数据质量与局限

- 同期若调整 O365 反垃圾策略、租户阻止名单、邮件流规则或公共邮箱域清单，必须记录时间与影响范围。
- 促销季、招聘季、供应商通知和安全事件可能改变公共邮箱正常/垃圾邮件比例；试点期间须每日记录流量结构变化。
- Graph/Logic Apps 通知可能延迟、丢失或重复；需通过幂等键、重试、生命周期通知和每日对账识别缺口。实际故障及修复情况待记录。
- 本试点仅覆盖公司 O365 租户、指定试点用户和已列入清单的公共邮箱域；结果不自动适用于所有外部域、其他邮件平台或未来攻击类型。
- AI 可能受到提示词注入、模型漂移、语言差异和附件不可见影响；邮件正文可能含个人信息与商业秘密，必须执行最小权限、最短留存、加密、访问审计和区域合规要求。

因此首阶段建议仅旁路评分并由人工复核，不让模型直接删除邮件。即使试点成功，也只能支持对已验证范围进行分阶段上线，不能证明能够识别所有未知垃圾邮件或钓鱼风险。

结果解释

当前无观测结果，无法验证假设。试点结束后，应将召回率变化与误报、处理时延及分群一致性共同解释；统计显著但业务收益很小，或总体提升由单一服务商驱动，都不足以支持全面上线。

当前建议是批准受控旁路试点，而不是直接自动拦截。预期收益是更早识别跨账号群发和语义型垃圾邮件；主要成本包括模型调用、日志存储、人工标注和运营维护。方案可通过停用规则快速回退，但数据隐私、误报和持续运维仍需在试点中验证。

决策记录

事项	决策
当前建议	进入受控旁路试点；尚未批准自动隔离或删除
决策日期	待正式批准
批准角色	待确认：邮件管理员、信息安全、隐私/合规、业务负责人
上线方式	旁路评分 → 人工复核 → 小范围审批 → 另行评估自动隔离
回退触发	误报超阈值、关键正常邮件受阻、数据泄露、审计缺口或服务无法安全降级
后续验证	完成 4 周试点、双人标注、每日对账、指标复算与最终评审

试点后行动

1. 先完成权限、域清单、白名单和留存策略评审；随后启用旁路采集与 AI 评分；达到门槛后再对小范围用户启用人工审批，最后才评估自动隔离。
2. 每日监控邮件量、错误率、处理时延和高风险告警；每周复核混淆矩阵及误报案例；进入自动隔离后至少连续监控 4 周。
3. 分别验证含链接、含附件、多人群发和领导冒充场景；对不同公共邮箱服务商及不同业务部门进行复测。
4. 评估基于历史通信关系、URL 信誉、发件认证与相似邮件聚类的增量价值，并比较规则模型与大模型的成本效果。
5. 归档版本化提示词、模型版本、规则配置、标注规范、去标识化样本摘要和决策记录；明确邮件运营与信息安全的长期责任人。

附录 A：指标定义

- 垃圾邮件召回率：AI 判为垃圾且人工确认的唯一邮件数 $\div$ 人工确认垃圾邮件总数；按冻结的纳入范围计算。
- 正常邮件误报率：AI 判为垃圾但人工确认正常的唯一邮件数 $\div$ 人工确认正常邮件总数。
- F1 分数：垃圾邮件类别精确率与召回率的调和平均数，用于平衡漏报和误报。
- 端到端处理时延：从分析队列收到邮件到生成结构化判定的时间；报告中位数、P95 和 P99。
- 未处理率：因超时、格式、权限或服务故障未生成有效判定的唯一邮件数 $\div$ 符合条件的唯一邮件总数。

附录 B：分析说明

- 计划使用配对混淆矩阵比较现有判定与 AI 判定；召回率和误报率报告 95%置信区间，配对差异可使用 McNemar 检验或配对自助法。实际查询、代码、模型与提示词版本待试点冻结后记录。
- 建议停止条件：发现未授权数据外传；发生业务关键正常邮件自动阻断；正常邮件误报率超过 1%；连续 30 分钟无法安全降级；或审计日志出现无法弥补的缺口。任何中期读取和计划偏差必须登记。
- 每日以 Exchange 邮件跟踪记录与分析队列按 Network Message ID 对账；重复通知必须去重，漏数须标记并说明是否补采。双人标签冲突由第三方复核。最终签字人待确认。
- 本文档依据当前讨论形成，未包含实际租户配置导出、真实邮件样本或试点结果。所有阈值为建议值；开始试点前须由邮件管理员、信息安全及隐私/合规负责人共同确认。